

CRYPTOGRAPHY

& INFORMATION SYSTEM SECURITY



Modul praktikum: Security Planning

Daftar Isi

Daftar Isi.....	2
Overview Risk Management.....	3
Threat Modeling.....	3
Risk Measurement.....	4
Analisis Kuantitatif.....	5
Analisis Kualitatif.....	5
Risk Treatment Plan.....	7
Tugas.....	8
Daftar Pustaka.....	10
Tim Asisten Praktikum.....	10

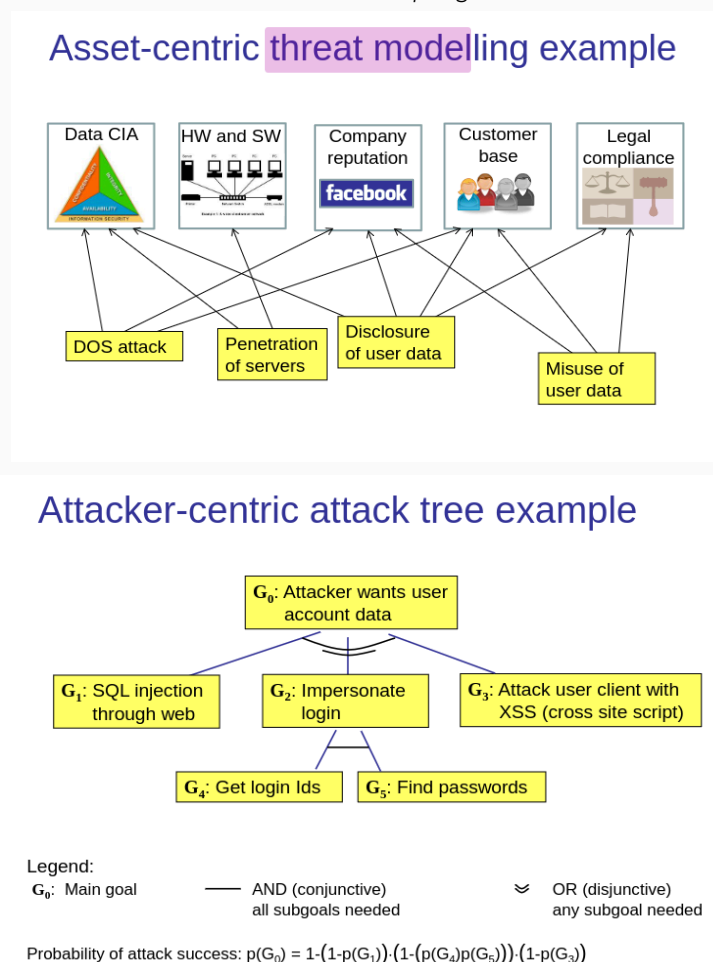
Overview Risk Management

Risk management dalam konteks ini berkaitan dengan asset security. Dalam melakukan management, diperlukan data-data yang *possible* berdampak pada masa mendatang. Manajemen tidak hanya di awal ataupun di akhir tapi di setiap langkah. Contohnya, SDLC yang dipilih adalah *Waterfall*, maka pada langkah requirements hingga implementation, dirancang *Threat Model*. Kegunaannya agar modelnya segera dapat dipakai di level management agar management-nya selalu adaptif.

Threat Modeling

Kita mendefinisikan threat modeling sebagai proses mendeskripsikan kemungkinan dampak buruk pada aset yang disebabkan oleh spesifik sumber threat (Maymí & Harris, 2022). Untuk mengetahui threat, ada beberapa metode, seperti security attack pada Modul 6. Hasil temuan attack tersebut dimodelkan menjadi threat model. Berikut beberapa contoh modelnya.

Gambar 1. Contoh Threat Model
Sumber: PPT UiO Spring 2015



Untuk memulai threat modeling, kita perlu memetakan aset, threat actor yang relevan, dan bentuk ancaman yang mungkin terjadi. Cara paling mudah adalah dengan berjalan melalui setiap aliran data pada DFD dan bertanya, siapa yang mungkin menyalahgunakan ini dan bagaimana caranya. Input threa

t modeling sendiri bisa berasal dari dua sumber, yaitu hasil penetration testing atau security audit seperti di modul sebelumnya atau analisis terhadap desain sistem (untuk sistem yang belum benar-benar jadi).

Aset	Klasifikasi	Threat Actor	Threat	Dampak Potensial
Data Pembayaran	Confidential	External Attacker	SQL Injection pada endpoint transaksi	Kebocoran data finansial nasabah secara massal
Password User	Private	External Attacker	Password hash terekspos di API response	Hash dapat di-crack menggunakan lookup table
Session Token	Private	External Attacker	JWT manipulation algorithm	Privilege escalation ke role admin
Data Transaksi	Private	(isi)	IDOR pada endpoint transaksi	(isi)
(isi)	(isi)	(isi)	Brute force pada endpoint login	(isi)

Framework:

Salah satu framework untuk threat modeling adalah STRIDE. STRIDE mengevaluasi desain sistem menggunakan flow diagram, system entity, dan event terkait sistem tersebut. OWASP juga menyediakan informasi mengenai threat modeling. Gunakan framework sesuai kebutuhan.

Pada dasarnya, pencarian threat bersifat bebas (non-formal) dan diformalkan menjadi model, bukan sebaliknya.

Risk Measurement

Temuan threats akan memperjelas aset apa saja yang kemungkinan mendapat ancaman. Hal ini diukur sebagai resiko. Pada praktiknya, ancaman tidak selalu diatasi dengan metode komputer seperti pada modul-modul sebelumnya. Dalam beberapa kasus, ada celah yang dijaga sebagai *backdoor* sehingga menjadi risiko selama *backdoor* masih ada. (Maymí & Harris, 2022) mendefinisikannya sebagai risk evaluation yang dibagi menjadi dua jenis metode, kuantitatif dan kualitatif.

Analisis Kuantitatif

Dua metrik utama dalam analisis kuantitatif adalah Single Loss Expectancy (SLE) dan Annual Loss Expectancy (ALE), dengan formula sebagai berikut.

Metriks:

1. Single Loss Expectancy

$$\text{Asset Value} \times \text{Exposure Factor (EF)} = \text{SLE}$$

2. Annual Loss Expectancy

$$\text{SLE} \times \text{Annualized Rate of Occurrence (ARO)} = \text{ALE}$$

Asset Value adalah estimasi nilai aset yang terancam, mencakup kerugian finansial langsung, biaya pemulihan, potensi sanksi hukum, dan kerugian reputasi. Exposure Factor adalah persentase aset yang terdampak apabila satu insiden terjadi. ARO adalah estimasi frekuensi kejadian dalam satu tahun dan bisa berupa bilangan desimal, misalnya 0,3 berarti kira-kira sekali setiap tiga tahun.

Gambar 2. Contoh Analisis Kuantitatif Risiko

Sumber: Maymí & Harris, 2022

Asset	Threat	Single Loss Expectancy (SLE)	Annualized Rate of Occurrence (ARO)	Annualized Loss Expectancy (ALE)
Facility	Fire	\$230,000	0.1	\$23,000
Trade secret	Stolen	\$40,000	0.01	\$400
File server	Failed	\$11,500	0.1	\$1,150
Business data	Ransomware	\$283,000	0.1	\$28,300
Customer credit card info	Stolen	\$300,000	3.0	\$900,000

Table 2-3 Breaking Down How SLE and ALE Values Are Used

Analisis Kualitatif

Gambar 3. Matriks umum risiko secara kualitatif

Sumber: Maymí & Harris, 2022

Likelihood	Consequences				
	Insignificant	Minor	Moderate	Major	Severe
Almost certain	M	H	H	E	E
Likely	M	M	H	H	E
Possible	L	M	M	H	E
Unlikely	L	M	M	M	H
Rare	L	L	M	M	H

Figure 2-4 Qualitative risk matrix: likelihood vs. consequences (impact)

Gambar 4. Contoh Analisis Kualitatif Risiko

Sumber: Maymí &
Harris, 2022 (4.a) dan PPT UiO Spring 2015 (4.b)

Threat = Hacker Accessing Confidential Information	Severity of Threat	Probability of Threat Taking Place	Potential Loss to the Organization	Effectiveness of Firewall	Effectiveness of Intrusion Detection System	Effectiveness of Honeypot
IT manager	4	2	4	4	3	2
Database administrator	4	4	4	3	4	1
Application programmer	2	3	3	4	2	1
System operator	3	4	3	4	2	1
Operational manager	5	4	4	4	4	2
Results	3.6	3.4	3.6	3.8	3	1.4

Threat scenario:	Existing controls & vulnerabilities:	Asset impact:	Impact level:	Likelihood description:	Likelihood:	Risk level:
Compromise of user password	No control or enforcement of password strength	Deleted files, breach of confidentiality and integrity	MODE RATE	Will happen to 1 of 50 users every year	MEDIUM	HIGH
Virus infection on clients	Virus filter disabled on many clients	Compromise of clients	MODE RATE	Will happen to 1 in 100 clients every year	HIGH	EXTREME
Web server hacking and defacing	IDS, firewall, daily patching, but zero day exploits exist	Reputation	MINOR	Could happen once every year	MEDIUM	MODE RATE
Logical bomb planted by insider	No review of source code that goes into production.	Breach of integrity or loss of data	MAJOR	Could happen once every 10 years	UNLIKELY	MODE RATE

Berbeda dengan analisis kuantitatif, analisis kualitatif menggunakan skala kategoris untuk menilai likelihood dan impact setiap risiko tanpa bergantung pada angka yang presisi. Hasilnya dipetakan ke dalam risk matrix seperti pada Gambar 3.

Threat	Likelihood	Impact	Risk Level
SQL Injection	High	Critical	Critical
Exposed Hash	High	Medium	High
JWT Manipulation	Medium	High	High
IDOR	(isi)	(isi)	(isi)
Brute Force	(isi)	(isi)	(isi)

Metodologi Asesmen Risiko:

Metodologi yang umum digunakan ada 4, yaitu

1. NIST SP 800-30
2. Facilitated Risk Analysis Process(FRAP bukan FURAB gaess)
3. Operationally Critical Threat, Asset, And Vulnerability Evaluation (OCTAVE)
4. Failure Modes and Effect Analysis (FMEA)

Risk Treatment Plan

Di level manajemen, seluruh hasil analisis sebelumnya direspon untuk dicanangkan treatmentnya. Berdasarkan ISO/IEC 27005, ada 4 jalan keluar untuk setiap risiko:

1. Mitigation, implementasikan kontrol sampai ke level yang dapat diterima
2. Accept, sekaligus berharap gak ada yang sadar, termasuk Tuhan. Asumsinya, dampak dari risiko tersebut lebih kecil dari biaya treatment.
3. Transfer, mentransfer risiko ke entitas lain seperti asuransi.
4. Avoid, tidak mengimplementasikan sistem informasi yang menimbulkan risiko tersebut atau mengubah praktik bisnis sehingga risiko tersebut tidak ada lagi atau berkurang hingga ke tingkat yang dapat diterima.

Threat	Risk Level	Label	Strategi/Alasan

SQL Injection	Critical	M	Implementasi parameterized query pada seluruh endpoint yang menggunakan input user. Estimasi biaya sekitar Rp 15.000.000 untuk satu sprint developer, jauh di bawah ALE Rp 480.000.000. Return on investment sangat jelas.
Exposed Hash	High	M	Definisikan schema response secara eksplisit menggunakan serializer atau DTO, sehingga field sensitif tidak pernah muncul di API response manapun. Biaya implementasi minimal dengan impact yang signifikan.
JWT Manipulation	High	(isi)	(isi)
IDOR	(isi)	(isi)	(isi)
Brute Force	(isi)	(isi)	(isi)

Some key notes below:

Untuk **Accept**, keputusan ini bukan berarti mengabaikan risiko begitu saja. Harus ada justifikasi berupa perbandingan ALE dengan estimasi biaya treatment, di mana ALE harus lebih kecil dari biaya treatment agar Accept masuk akal secara bisnis. Batas toleransi yang disepakati manajemen wajib didokumentasikan.

Untuk **Transfer**, pastikan ada entitas yang bisa dan mau menerima risiko tersebut. Tidak semua risiko memiliki produk asuransi atau pihak ketiga yang relevan, sehingga opsi ini tidak selalu tersedia.

Untuk **Avoid**, ini adalah opsi paling efektif secara keamanan tapi paling mahal dari sisi bisnis, karena berarti fitur atau bahkan seluruh sistem tidak diimplementasikan.

Tugas

Breathe a sigh of relief deh, kali ini tugasnya ez deh keknya ctf kemaren lumayan kan yah, anggap saja ini cooldown yagesya

1. Lengkapi seluruh bagian bertanda (isi) pada Tabel X (Threat Model), Tabel X (Analisis Kuantitatif), Tabel X (Risk Matrix), dan Tabel X (Risk Treatment Plan) untuk web pembayaran dummy tadi. Sertakan juga alasan/justifikasi singkat untuk setiap keputusan treatment yang dipilih.

Output format: Dokumen laporan dalam bentuk PDF. formatnya NIM_laporan.pdf. Satuin aja sama yang soal nomer 2 biar gampang 1 pdf sajah

2. Silverash needs your help! Tolong yah untuk Buatkan laporan risk management lengkap untuk bisnis kjeragnya sekarang because new thingy is happening in the north (idk havent read the latest one, but i think priestess is on it again). Supaya Karlan Trading Company can keep prospering forevermore, berikut syarat-syaratnya:
- Bukan web pembayaran simpel atau variasinya
 - Memiliki minimal 3 komponen utama yang berbeda (contoh: frontend, backend, database, IoT device, dsb.)
 - Memiliki minimal 3 tipe pengguna dengan role berbeda
 - Ada minimal 3 jenis aset data dengan klasifikasi yang berbeda (referensi Tabel Klasifikasi di Modul 1)
 - DFD level 0 dan level 1 disertakan

Isi laporan:

- Deskripsi singkat sistem (maksimal setengah halaman, gausah yapping amat)
- DFD level 0 dan level 1 (ini nanti masih TBD, ditunggu sjah)
- Threat model (minimal 5 identified threats, format mengikuti Tabel)
- Risk measurement kuantitatif (minimal 3 threats, sertakan justifikasi nilai Asset Value dan ARO)
- Risk measurement kualitatif (semua identified threats)
- Risk treatment plan (semua threats, dengan reasoning yang jelas per item)

Output format: Dokumen laporan dalam bentuk PDF. formatnya NIM_laporan.pdf. Satuin aja sama soal yang nomer 1 biar gampang 1 pdf aja

Deadline:

C1: 18/05/2026 23:59 WIB

C2: 19/05/2026 23:59 WIB

[Link Pengumpulan](#)

Daftar Pustaka

Maymí, F., & Harris, S. (2022). *CISSP all-in-one exam guide* (Ninth edition). McGraw Hill.

Tim Asisten Praktikum

1. Franklin
2. **Lyan (PIC Praktikum)**
3. Ichsan
4. Alvin
5. Radhi